



Introduction to *G.R.C*

Governance, Risk and Compliance

KamiLimu cohort 10 - Cybersecurity



Let's think for a minute:



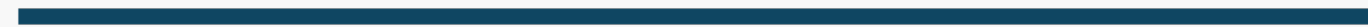
What would you say is the most important thing to a business?

What laws would you say apply to the following:

- 1.Mama mboga?
- 2.Bank?
- 3.Gaming company - (multi-national)

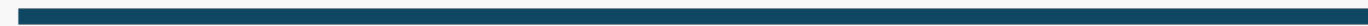
Can any business exist without the law?





G.R.C - **Governance, Risk and Compliance** works to align IT and business - ensuring that policies, processes and regulation structures meet an organization's risk and business objectives.

People, Process & Technology - core tenets of cyber security

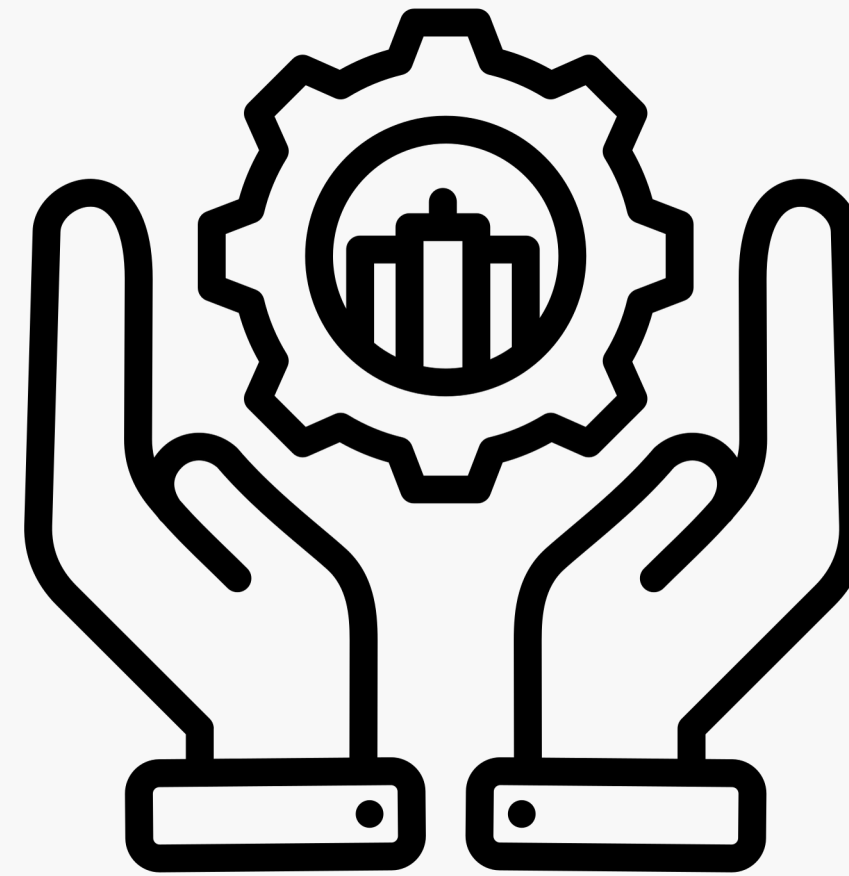


Governance

Governance is the leadership and key processes of an organization that allow it to function as it needs to.

This looks like:

- Boards
- Policies, strategies, guidelines
- Budgets
- Officials (or key people who make decisions).

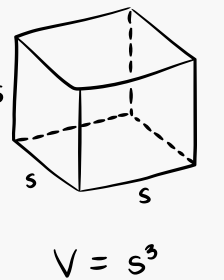




Risk

Risks are all the potential “bad” things that can happen to an organization. These can stem from the environment e.g. tsunamis, hackers, loss of power (electricity) etc.

- Risk in GRC works to measure these “bad” things and the likelihood that they can happen - seriously, there’s math involved



- And once everyone knows their risks, they decide what to do about them - including ignoring them 😊



Compliance

These are all the elements an organization is expected to adhere to - think, laws, regulations etc.

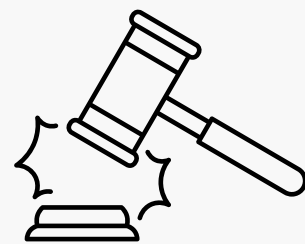
These can span regular regulation such as:

- Tax law
- Employee Law



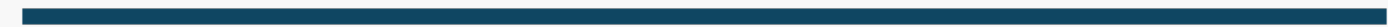
To cyber specific laws and regulation e.g.:

- Data Protection regulation (which governs how to protect data)
- IT related laws - the Kenya Computer Misuse & Cybercrime Act is an example





Mini break
Questions?



Key frameworks



ISO27001

Created by the International Organization for Standardization, 27001 represents a framework to assess ISMS

COBIT

The Control Objectives for Information and Related Technologies developed by ISACA

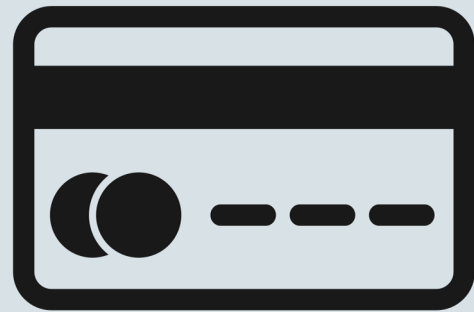


NIST - Cyber Security Framework - CSF & the 800- series

A series of American frameworks that have seen widespread adoption. It guides companies on managing cyber security risks.



Other frameworks: industry specific



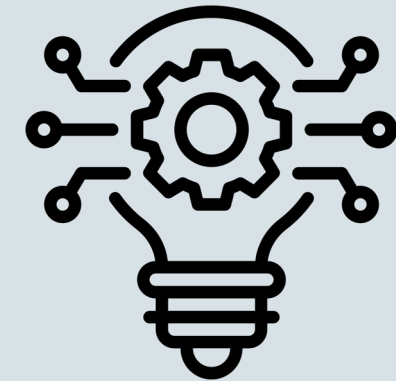
PCI-DSS

- The Payment Card Industry Data Security Standard.
- Protects and recommends best practice for any entities that manage cards e.g. Visa



SWIFT

- Applies to inter-bank messaging and transactions.
- Managed by SWIFT - Society for Worldwide Inter-bank Financial Telecommunication



Cloud/AI/Crypto frameworks

- Frameworks governing new and emerging technologies
- Companies and governments are racing to develop and address key issues in new tech.



What is missing?
*Do you think the discussed
frameworks are comprehensive?*



Area of note: Data Protection

Kenya - Data Protection Act, 2019 & accompanying regulations

- Developed in 2019 to meet a majority (kind of) of the requirements of the GDPR but for Kenyan citizens
- Causing a regulatory headache for companies locally due to non-compliance.

General Data Protection Regulations - (GDPR) - EU

- Developed by the European Union - around 2016.
- In place to address data protection for EU citizens - regardless of their location/jurisdiction.
- Groundbreaking law on Data Privacy.

Global data protection frameworks & regulations

- Frameworks governing new and emerging California Consumer Privacy Act (CCPA) - USA
- Lei Geral de Proteção de Dados (LGPD) - Brazil - Data Protection law from Brazil that applies if data processing is handled in Brazil.
- etc....

Assessment methodology

How do you work out if a company is doing ok: GRC-wise?



Assessment Questionnaires - interviews

- Most provided frameworks have an element of available assessment questionnaires that can be used for assessment.

Evidence gathering & validation

- It is hard to be sure about a client's posture without seeing - seeing is believing
- Gather evidence in the form of seeing, hearing, testing etc.

Reporting

- Explain to the organization where their "gaps" are
- Give recommendations on areas they can improve



Practice lab - TryHackMe
cybergovernanceregulation





Further study (resources)

Frameworks

ISO - <https://iso.org>

NIST - <https://www.nist.gov/cyberframework>

COBIT: <https://www.isaca.org/resources/cobit>



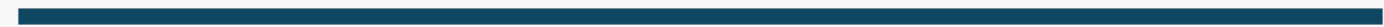
Further study - certifications

- ISC2
<https://www.isc2.org/certifications/cgrc>
 - CIPP (privacy):
<https://iapp.org/certify/cipp/>
 - ISO audit certificates:
<https://pecb.com/en/education-and-certification-for-individuals/iso-iec-27001>
-





Questions?





Thank you

